LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

# Synology DSM C3RB3R Ransomware and CVE-2026-13684 Exposure Priority Update

CVE / Vulnerability Threat Intelligence Report

| | |
|---|---|
| **Classification** | TLP:CLEAR |
| **Published** | 2026-11-08 |
| **Version** | 1.0 |
| **Author** | Lost Boys Cyber |
| **Report Type** | CVE / Vulnerability Threat Intelligence Report |



Published: 2026-11-08 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

# Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review and Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Mitigation and Workarounds
8. Detection Engineering
    8.1. Detection Logic Summary
    8.2. SIEM Hunt Query
    8.3. Network Detection Logic
9. Threat Hunting
    9.1. Hunt Hypothesis
10. MITRE ATT&CK Mapping
11. Validation / Lab Testing
12. Recommended Actions Summary
13. References

# Synology DSM C3RB3R Ransomware and CVE-2026-13684 Exposure Priority Update

## 1. Executive Summary

Public reporting reviewed on 2026-11-08 indicates ransomware activity against outdated Synology DiskStation Manager (DSM) devices. Synology's September advisory documents three remotely reachable DSM flaws, including CVE-2026-13684, that can permit file read/write or denial of service in affected builds. Supporting reporting associates current ransomware response activity with outdated exposed NAS appliances; the public record does not establish a complete, independently reproducible exploit chain for every reported victim.

The operational priority is not attribution. Organizations should identify every externally reachable DSM management interface, confirm the fixed DSM build against Synology's advisory, remove unnecessary internet exposure, preserve evidence on suspected systems, and validate offline or immutable backup recovery. Treat a device with unexpected encryption, ransom notes, account changes, or unfamiliar remote administration activity as an incident.

## 2. Vulnerability Metadata

| Field | Value |
|---|---|
| CVEs | CVE-2026-13684; CVE-2026-13639; CVE-2026-13635 |
| Product | Synology DiskStation Manager (DSM) |
| Vendor advisory | Synology_SA_26_13, published 2026-09-18 |
| CVE-2026-13684 impact | Remote file read/write and denial of service through SCGI improper output encoding/escaping |
| Affected versions | DSM prior to 7.2.1-69057-12, 7.2.2-72806-9, 7.3.2-86009-4, and 7.4-90075, per advisory-derived records |
| Exploitation context | Ransomware reporting describes attacks against outdated DSM; public reporting must not be read as proof that every intrusion uses every CVE |
| Confidence | Medium for current prioritization; high for vendor remediation scope |

## 3. Source Review and Confidence

| Source | Contribution | Confidence |
|---|---|---|
| Synology SA_26_13 | Primary affected-product and remediation authority | High |
| OpenCVE record | CVE description and affected-version corroboration | Medium |
| The Hacker News | Current ransomware targeting context | Medium |
| Additional incident reporting | Supporting context for outdated-DSM exposure prioritization | Low-Medium |

The vendor advisory is authoritative for patch scope. Current reporting supports urgent defensive revalidation but does not supply verified attacker infrastructure, hashes, a universal ransom-note string, or a public forensic timeline for every claimed event. This report deliberately does not manufacture those indicators.

## 4. Vulnerability Details

CVE-2026-13684 is described as improper encoding or escaping of output in DSM's SCGI component. The stated outcomes include arbitrary file read or write and denial of service. A reachable NAS management surface can be especially consequential because it may contain business data, backup repositories, directory integration material, and service credentials. Exploitability depends on actual version, exposure, configuration, and the attack path; a CVE record alone does not prove compromise.

## 5. Attack Scenarios

1. An internet-exposed, outdated DSM appliance is discovered and targeted through a vulnerable management or application surface.
2. An attacker who gains write capability alters files, stages tooling, creates persistence, or prepares encryption and data theft.
3. A compromised NAS is used to destroy or encrypt accessible backups, increasing the impact of a separate endpoint or identity compromise.

## 6. Affected Products and Exposure

| Exposure Pattern | Why It Matters | Defender Action |
|---|---|---|
| DSM reachable from the internet | Increases discovery and exploit opportunity | Restrict to VPN or approved admin networks; patch immediately |
| NAS hosts backup repositories | Encryption or deletion can defeat recovery | Confirm immutable/offline copies and restore tests |
| NAS joined to directory or using service credentials | May expose broader identity paths | Rotate affected credentials after confirmed compromise |
| Fully patched, restricted DSM | Reduces known-CVE exposure | Continue monitoring and configuration review |

## 7. Mitigation and Workarounds

| Priority | Owner | Action |
|---|---|---|
| Critical | Storage / Infrastructure | Inventory DSM versions and update affected appliances to the vendor-fixed build for their release train. |
| Critical | Network Engineering | Remove direct internet exposure unless a documented business requirement remains; enforce VPN, allowlists, and MFA. |
| Critical | Incident Response | Isolate any NAS with encryption, ransom notes, anomalous users, or unexplained remote admin activity; preserve logs before rebuild. |
| High | Backup Owners | Test a clean restore from offline or immutable backup and verify backup |

| | | |
|---|---|---|
| | | credentials are segregated. |
| High | SOC | Hunt for appliance-originated anomalous outbound connections and administrator activity. |

## 8. Detection Engineering

### 8.1. Detection Logic Summary

| Signal | Telemetry Source | Analytic Goal |
|---|---|---|
| Publicly reachable DSM management ports | External attack-surface inventory | Find systems requiring immediate ownership review |
| New DSM administrator or privilege change | DSM audit logs / SIEM | Identify unauthorized account manipulation |
| Unusual NAS outbound connections | Firewall, proxy, NetFlow | Find possible command-and-control or exfiltration |
| High-rate file rename/write activity | NAS audit logs | Detect encryption-like behavior |

### 8.2. SIEM Hunt Query

```
// Adapt parser field names for DSM, firewall, or NetFlow telemetry.
CommonSecurityLog
| where TimeGenerated > ago(30d)
| where DeviceProduct has "Synology" or Message has "DSM"
| where Message has_any ("admin", "user", "login", "privilege", "encrypt", "ransom")
| project TimeGenerated, Computer, SourceIP, DestinationIP, Message
| order by TimeGenerated desc
```

### 8.3. Network Detection Logic

```
title: Synology DSM Management Access From Unapproved Source
status: experimental
logsource:
  category: firewall
detection:
  selection:
    destination_port|contains:
      - '5000'
      - '5001'
  filter_private_admin_source:
    source_ip|cidr:
      - 10.0.0.0/8
      - 172.16.0.0/12
      - 192.168.0.0/16
  condition: selection and not filter_private_admin_source
level: high
```

## 9. Threat Hunting

### 9.1. Hunt Hypothesis

If an exposed DSM device was abused before remediation, logs may show unexpected administrative actions, remote access from rare sources, or new outbound communications near periods of abnormal file activity.

```
let nas = dynamic(["synology", "diskstation", "dsm"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where InitiatingProcessCommandLine has_any (nas) or RemoteUrl has_any (nas)
```

```
| summarize Connections=count(), RemoteHosts=make_set(RemoteUrl, 20) by DeviceName, bin(Timestamp, 1h)
| where Connections > 20
| order by Connections desc
```

## 10. MITRE ATT&CK Mapping

| Technique | Name | Evidence / Rationale |
|---|---|---|
| T1190 | Exploit Public-Facing Application | Applicable analytic hypothesis for exposed DSM services; not a claim about each incident. |
| T1078 | Valid Accounts | Hunt for unexpected administrator use after suspected compromise. |
| T1486 | Data Encrypted for Impact | Ransomware-impact analytic to validate through file and backup telemetry. |

## 11. Validation / Lab Testing

This production report did not reproduce exploitation or execute ransomware. Validation consisted of source comparison, report preflight, render verification, and review of hunt logic for analyst adaptation. Operators must validate version thresholds and log field names in their own DSM and SIEM deployment.

## 12. Recommended Actions Summary

| Priority | Owner | Action |
|---|---|---|
| Critical | CISO / Infrastructure | Complete same-day exposure and patch-state inventory. |
| Critical | SOC / IR | Triage any NAS exhibiting encryption or unauthorized administration. |
| High | Backup Team | Prove recoverability with an isolated restore exercise. |
| High | Risk / Procurement | Document third-party NAS and managed-backup ownership. |

## 13. References


- Synology, Synology_SA_26_13: https://www.synology.com/en-global/security/advisory/Synology_SA_26_13
- OpenCVE, CVE-2026-13684: https://app.opencve.io/cve/CVE-2026-13684
- The Hacker News, Synology NAS Devices Targeted in Ransomware Attacks: https://thehackernews.com/2026/11/synology-nas-devices-targeted-in.html
- CyberExperts, C3RB3R ransomware and DSM context: https://cyberexperts.com/2026-10-30-synology-dsm-c3rb3r-ransomware/